

Чемоданчик ИБ-специалиста: Физические инструменты, без которых аудит и пентест — это фикция

 redsec.by/article/chemodanchik-ib-specialista-fizicheskie-instrumenty-bez-kotoryh-audit-i-pentest-eto-fiksiya

Red Teams | 28 января 2026



Почему «физика» критична в эпоху облаков

В мире кибербезопасности существует опасная иллюзия, что вся работа происходит исключительно в виртуальном пространстве. Мы привыкли думать о фаерволах, эксплойтах нулевого дня, SQL-инъекциях и APT-группировках. Но реальность такова: самые дорогие и фатальные ошибки в ИБ совершаются не в строках кода, а в

пыльных серверных шкафах, на полках с коммутаторами и в невидимом радиоэфире.

Кибербезопасность живет не только в терминале Kali Linux. Она живет там, где медный кабель входит в порт, где радиоволна встречается с антенной, и где жесткий диск изымается для криминалистического анализа.

Представьте ситуацию: аудитор приезжает на критически важный объект инфраструктуры. У него в рюкзаке топовый ноутбук, купленный за три тысячи долларов, установлены все мыслимые фреймворки. Но он обнаруживает, что забыл консольный кабель за 10 долларов или специфический переходник. Результат? Аудит сорван. Время простоя стоит десятки тысяч долларов. Заказчик в ярости. Репутация уничтожена.

Или другой сценарий: пентестер находит физический доступ к сетевой розетке, но не может подтвердить уязвимость, потому что у него нет инструмента для проверки целостности кабеля, и он не понимает, почему нет линка.

Основная философия: Чемоданчик ИБ-специалиста — это не набор «гаджетов» и лишних вещей. Это физическое продолжение вашей компетенции. Это экзоскелет вашего профессионализма в полевых условиях. Правильный, стандартизированный инструмент решает 80% рутинных проблем, позволяя вам сфокусироваться на оставшихся 20%, требующих интеллекта и импровизации.

Принципы сборки чемоданчика: Философия EDC

Прежде чем мы начнем бездумно скупать все, что блестит на витринах магазинов электроники, необходимо усвоить четыре фундаментальных правила формирования профессионального набора (EDC — Every Day Carry).

1. Компактность и Мобильность

Каждый грамм имеет значение. Если вы часто летаете в командировки, вы знаете: ваш кейс должен гарантированно помещаться в ручную кладь (Carry-on). Сдача оборудования в багаж — это риск потери, кражи или повреждения. На ваши ноги и спину ложится вес экипировки. Кейс для повседневных задач не должен превышать 5–6 кг. Эргономика — это часть вашей работоспособности. Усталый специалист делает ошибки.

2. Повторяемость и Стандартизация

Это принцип военных и пилотов. Ваш «тревожный чемоданчик» должен быть собран одинаково каждый раз. Нельзя импровизировать перед выездом. Если сегодня вы

выложили USB-хаб, чтобы положить бутерброд, завтра вы забудете вернуть его на место, и именно завтра он понадобится.

Правило: Составьте чек-лист. Распечатайте его. Ламинируйте. Проверяйте комплектацию по списку перед выходом и перед уходом с объекта.

3. Надёжность и Инвестиции

Инструмент — это инвестиция, а не расходная статья. Не покупайте «ноунейм» китайского производства на один раз. Отвертка Wiha или Wera прослужит пять лет, сохраняя шлицы ваших винтов и нервы. Безымянная отвертка из супермаркета «слижет» шлиц на винте дорогого сервера в самый неподходящий момент. Дешевый кабель порвется внутри изоляции, и вы потратите два часа на диагностику сети, которой нет.

4. Назначение (Function over Price)

Важен класс инструмента и его соответствие задаче. Самый дорогой тестер для сертификации сетей (типа Fluke Versiv) бесполезен для пентестера, если он весит 5 кг и требует полчаса на настройку. Вам часто нужен простой, но надежный прибор. Выбирайте инструмент по решаемой задаче, а не по ценнику.

Матрица ролей инструментов

Чтобы навести порядок в хаосе, разделим всё на четыре функциональные категории:

Роль	Зачем это нужно	Примеры
Доступ & Подключение	Физическая коммутация. Задача — «врезаться» в систему, получить линк, подать питание.	Консольные кабели, патч-корды, переходники, USB-хабы.
Измерение & Диагностика	Разведка. Проверить, что реально находится на проводе и в эфире. Отличить программный сбой от аппаратного.	Кабельные тестеры, Wi-Fi анализаторы, мультиметры.
Фиксация доказательств	Forensic. Собрать улики без изменения данных. Сохранить юридическую значимость (Chain of Custody).	Write-blocker, защищённые USB, камеры, пломбы.
OPSEC & Безопасность	Защита самого специалиста. Не оставить следов, не потерять свои данные, соблюдать гигиену.	Шифрованные носители, журналы учета, перчатки, замки.

Часть 1. Базовый механический набор: Кинетика

ИБ-специалист — это наполовину инженер. Вам придется разбирать корпуса точек доступа, монтировать оборудование в стойку, вскрывать кабель-каналы и розетки.

1.1. Отвёртки и биты: Анатомия доступа

Вы не сможете подключиться к JTAG-интерфейсу роутера, если не сможете открыть его корпус.

Обязательная номенклатура бит:

- **PH (Phillips):** PH0, PH1, PH2, PH3. Самый распространенный стандарт. PH2 — король серверных стоек.
- **PZ (Pozidriv):** Имеет дополнительные насечки. Часто встречается в европейском электромонтажном оборудовании. Не путать с PH!
- **SL (Slot/Плоская):** 2–4 мм. Для клеммников и старого оборудования.
- **Torx (Звездочка):** T5, T6, T8, T10, T15, T20, T25, T30. Стандарт для электроники (HDD, ноутбуки).
- **Security Torx (Tamper-resistant):** Критически важно! Это «звездочка» с отверстием посередине (маркировка TR или ST). Производители (Cisco, HP) ставят их специально, чтобы обычные пользователи не вскрывали корпуса. Без них вы беспомощны.

Типичная ошибка: Забыли Security Torx. Приехали на аудит физической безопасности. Нужно проверить, нет ли внутри коммутатора «жучка». Винты защищены штифтом. Вскрыть невозможно. Аудит провален.

Вредный совет: Попытаться выломать штифт тонкой отверткой. Результат: сломанный инструмент, сорванный шлиц, царапины на корпусе, скандал.

Рекомендация профи: Используйте наборы от **Wiha** (System 4) или **Wera** (Kraftform Kompakt). Они компактны, сталь закалена правильно (не крошится и не гнется), рукоятки ESD-safe (антистатические).

1.2. Инструменты точной работы

Когда пальцы слишком толстые для микроэлектроники.

- **Пинцет (Нержавейка, ESD):** Обязательно антимагнитный. Достать упавший винтик из недр материнской платы сервера под напряжением — задача для хирурга. Установить джампер (перемычку) для сброса пароля BIOS.
- **Мини-плоскогубцы / Тонкогубцы:** Удерживать гайку, согнуть ножку компонента.
- **Бокорезы (Flush cutters):** Идеально ровно обрезать стяжку (чтобы не царапала руки) или зачистить провод.
- **Wire Stripper (Стриппер):** Инструмент для снятия изоляции. Если нужно срочно сделать скрутку или обжать кабель, зубами изоляцию снимают только дилетанты.
- **Мультитул (Leatherman Wave/Surge):** Спасательный круг. Нож, пила, напильник. Но помните: в самолет с ним нельзя!

1.3. Расходные материалы: Мелочи, спасающие жизнь

Без расходников любой инструмент бесполезен.

- **Стяжки (Zip-ties):** Чёрные, нейлоновые, стойкие к UV. 100–150 мм. Всегда имейте запас в 100 штук.
- **Velcro (Липучки):** Многоразовое решение. Ценятся выше, так как позволяют добавлять кабели в жгут без разрезания.
- **Изолента:** Двух видов. Классическая ПВХ (Blue/Black) для изоляции. Тканевая (Tesa) для формирования жгутов — она не липнет к рукам и оборудованию, выглядит профессионально.
- **Термоусадка:** Набор трубок разного диаметра. Для ремонта поврежденной изоляции зарядных устройств.
- **Маркировка:** Перманентный маркер (Sharpie) и самоклеящиеся этикетки. Неподписанный кабель — это мина замедленного действия.

Часть 2. Кабели и переходники: Нервная система

Статистика неумолима: 70% проблем на выезде решаются наличием правильного кабеля. Нет кабеля — нет коннекта. Нет коннекта — нет работы.

2.1. Ethernet и витая пара

Это кровеносная система любой сети.

Тип	Длина	Назначение
Патч-корд CAT6A (S/FTP)	0.3 м	«Коротыш». Для соединения ноутбука и свича, когда вы стоите с ним в обнимку у стойки. Не путается.
Патч-корд CAT6 (UTP/FTP)	2–3 м	Основной рабочий кабель. Достать до розетки под столом.
Патч-корд плоский	5 м	Запасной. Занимает минимум места в скрученном виде. Удобно просовывать в щели дверей.
Катушка (бухта)	50+ м	Крайний случай. Если нужно кинуть линк между этажами или зданиями по улице.

Ремкомплект:

- **RJ45 Коннекторы:** 20–50 штук. Желательно сквозные (Pass-through) — с ними легче работать в полевых условиях.
- **Кримпер (Обжимка):** Легкий, компактный инструмент (например, Klein Tools).
- **Зачем это аудитору?** Часто бывает так: вы приходите в серверную, а свободные патч-корды закончились или у всех сломаны защелки. Умение за 30 секунд обжать новый кабель вызывает уважение у местных админов.

2.2. Консольные кабели: Ключи от Царства

Сетевое оборудование уровня Enterprise (Cisco, Juniper, Huawei) не настраивается мышкой. Ему нужна консоль (CLI).

- **USB-to-RJ45 (Cisco Console):** Стандарт де-факто.
 - *Критический нюанс:* Чипсет. Избегайте дешевых кабелей на чипе **Prolific**. Их драйверы глючат, требуют старых версий Windows и часто выдают BSOD.
 - *Выбор профи:* Только чипсет **FTDI**. Он работает «из коробки» на Windows, macOS и Linux. Надежный, стабильный, поддерживает нестандартные скорости бод (baud rates).
- **USB-to-DB9 (RS-232 Serial):** Для старого «железа», промышленных контроллеров (SCADA), ИБП и систем контроля доступа.

- **Переходники:** USB-C to USB-A. Современные макбуки не имеют обычных портов, а большинство консольных кабелей — USB-A.

Типичная ошибка: Приехал на пусконаладку фаервола. Ноутбук — новый Dell XPS только с Type-C. Кабель — старый USB-A. Переходника нет. Приходится унижаться и просить переходник у секретаря или бежать в ближайший магазин электроники.

2.3. USB-экосистема: Адаптеры на все случаи жизни

Закон Мерфи гласит: у вас всегда будет разъем «папа», когда нужен «мама».

- **USB Hub (Активный):** Выбирайте хаб с внешним питанием (Pass-through charging). Если вы подключите к пассивному хабу внешний диск, Wi-Fi адаптер и SDR-приемник, порт ноутбука просто отключится по перегрузке по току. Рекомендуются модели от Anker или Satechi.
- **USB OTG (On-The-Go):** Позволяет подключить флешку или клавиатуру к смартфону/планшету. Полезно для мобильного пентеста (NetHunter).
- **Видео-адаптеры:** HDMI — это стандарт, но в серверных часто стоят старые мониторы с VGA или DVI. Имейте переходник *USB-C -> HDMI/VGA/DisplayPort*.
- **USB Ethernet Adapter:** Обязательно гигабитный. Если встроенная сетевая карта сгорит или портов нужно два (один для интернета, второй для атаки/мониторинга), этот адаптер спасет.

2.4. Интерфейсы накопителей (SATA/NVMe)

Для форензики и создания образов дисков. Здесь царит путаница стандартов, которая может стоить вам данных.

- **M.2 SATA vs M.2 NVMe:** Визуально похожи, электрически несовместимы.
 - *SATA:* Имеет два ключа (выреза) — B+M Key.
 - *NVMe:* Имеет один ключ — M Key.
- **Решение:** Универсальный внешний бокс (Enclosure), поддерживающий оба протокола (RTL9210B chipset). Либо профессиональный **Write-Blocker** (о нем ниже).

Часть 3. Диагностика сети: Глаза и уши

Вы подключились. Но есть ли сигнал?

3.1. Кабельный тестер: Wiremap

Самый простой прибор, который экономит часы.

- **Базовый (Continuity):** Показывает, есть ли гальваническая связь. Горят лампочки 1-8.

- **Продвинутый (Wiremap + TDR):** Показывает перепутанные пары (Split pairs), короткие замыкания и *расстояние до обрыва*.
- **Сценарий:** Вы подключаетесь к розетке, линка нет. Тестер показывает: «Обрыв пары на 45-м метре». Вы понимаете, что проблема не в вашем патч-корде, а где-то в потолке.
- **Рекомендация:** Jonard Tools LAN Scout или Klein Tools Scout Pro 3. Fluke MicroScanner — отлично, но дорого.

3.2. Карманная инфраструктура

Иногда вам нужно создать свою сеть внутри чужой.

- **Travel Router (Мини-роутер):** Легендарный **TP-Link TL-MR3020** или **GL.iNet** (slate/beryl).
Зачем: Поднять OpenVPN туннель до своего сервера, раздать Wi-Fi с 4G-модема, организовать MitM (Man-in-the-Middle) атаку для исследования IoT-устройства. Работает от Power Bank.
- **Мини-коммутатор (5 портов):** Неуправляемый свич в металлическом корпусе (TP-Link/Netgear). Позволяет подключить к одному порту в стене сразу и ноутбук, и тестер, и целевое устройство. Или настроить зеркалирование трафика (Port Mirroring) на управляемой модели.

3.3. Мультиметр

Не только для электриков. Проверить напряжение в блоке питания роутера, прозвонить предохранитель, проверить заземление в стойке (между корпусом сервера и стойкой не должно быть потенциала).

Часть 4. Wi-Fi инструменты: Война в эфире

Беспроводные сети невидимы, и проблемы с ними — самые мистические. «Интернет тормозит», «сигнал отваливается».

4.1. Wi-Fi адаптер для мониторинга

Встроенный адаптер вашего ноутбука создан для энергосбережения и Netflix, а не для хакерских атак. Он «глухой» и не умеет переходить в **Monitor Mode** (режим прослушивания эфира) и делать **Packet Injection** (инъекцию пакетов).

Золотой стандарт чипсетов:

- **Atheros AR9271:** Старый, но надежный. Работает с Kali Linux без бубна. (Пример: Alfa AWUS036NHA). Только 2.4 ГГц.

- **Realtek RTL8812AU / 8814AU:** Поддерживает 5 ГГц, AC стандарт. Мощный, дальнобойный. (Пример: Alfa AWUS036ACH, TP-Link Archer T4U v3).
- **MediaTek MT7921K:** Новое поколение с поддержкой Wi-Fi 6 (AX), но драйверы пока сырые.

4.2. Антенное хозяйство

Физику не обманешь.

- **Всенаправленная (Omni):** Штыревая антенна («палка»). Слушает все вокруг. Идеальна для первичной разведки.
- **Направленная (Directional - Yagi/Panel):** Работает как фонарик. Позволяет «услышать» сеть за километр или найти конкретный источник помех (например, неисправную микроволновку, глушащую Wi-Fi).

4.3. Спектральный анализ

Wi-Fi сканеры показывают только декодированные пакеты. Они не видят помех от Bluetooth, радионянь, микроволновок, аналоговых камер.

- **EkaHau Sidekick 2:** Вершина эволюции. Профессиональный инструмент за \$3000+. Содержит прецизионные спектроанализаторы. Стандарт для Site Survey.
- **HackRF One / SDR:** Программно-определяемое радио. Бюджетный способ увидеть спектр, но требует высокой квалификации.
- **Android-смартфон + софт:** Базовая диагностика (WiFi Analyzer) для быстрой оценки уровней сигнала (RSSI) и зашумленности каналов (SNR).

4.4. BLE и IoT: Взлом умного офиса

- **Flipper Zero:** «Тамагочи для хакеров». Умеет читать/эмулировать NFC, RFID, iButton, работать с радиопультами (Sub-GHz), анализировать ИК-сигналы. Незаменим для тестов систем контроля доступа (СКУД).
- **Proxmark3:** Тяжелая артиллерия для RFID. Клонирование пропусков, брутфорс ключей домофонов.

Часть 5. Форензика и Incident Response (IR)

Если вас позвали расследовать инцидент, ваша главная задача — не навредить.

5.1. Write-Blocker (Блокиратор записи)

Это священный грааль компьютерной криминалистики. При подключении диска к Windows, операционная система немедленно начинает менять метаданные: обновляет время последнего доступа, создает скрытые папки System Volume

Information, индексирует файлы.

Результат: Хэш-сумма диска меняется. Доказательства в суде признаются недопустимыми.

Решение: Аппаратный блокиратор записи (например, **Tableau TK35u**). Он физически пропускает команды чтения, но блокирует любые команды записи. ОС видит диск, может читать, но не может изменить ни бита.

5.2. Цепочка хранения (Chain of Custody)

- **Пломбы (Tamper-evident seals):** Одноразовые наклейки, которые оставляют надпись «VOID» или разрушаются при попытке отклеить. Ими опечатывают порты ноутбуков, кейсы с уликами.
- **Пакеты Фарадея:** Экранированные пакеты для телефонов/планшетов. Блокируют радиосигналы, чтобы устройство нельзя было удаленно стереть (Remote Wipe) до начала экспертизы.

5.3. Защищенные носители

Флешки для сбора логов должны быть с аппаратным шифрованием (например, Kingston IronKey). Если вы потеряете флешку с данными клиента — это конец карьеры.

Часть 6. Энергетика: Автономность

Кибербезопасность потребляет электричество.

6.1. GaN (Нитрид Галлия) Зарядки

Революция в мире блоков питания. Они в 2 раза меньше и легче кремниевых аналогов.

- Вам нужен блок на **100W–140W** с поддержкой протокола **PD 3.1** (Power Delivery). Он сможет одновременно заряжать мощный игровой ноутбук (рабочую станцию), телефон и Power Bank.
- *Пример:* Anker 747, Ugreen Nexode.

6.2. Power Bank: Резервуар энергии

- Емкость: 20,000–27,000 mAh (максимум, разрешенный в самолете — 100 Wh).
- Мощность: Должен выдавать 65W+ на выход USB-C, чтобы питать ноутбук. Обычная «банка» для телефона ноутбук не потянет.

6.3. Удлинитель-Пилот

В серверных розетки часто расположены неудобно или заняты. Компактный удлинитель (Power Strip) на 3 розетки с кабелем 1.5–3 метра — это спасение. Лучше брать модели с заземлением.

Часть 7. OPSEC и Логистика: Защита инструментов

7.1. Кейс

Мягкий рюкзак удобен, но жесткий кейс (Pelican, Nanuk) защищает оборудование от ударов, воды и пыли. Для перевозки дорогой электроники (Write-blocker, анализаторы) используйте кейсы с поролоновым ложементом.

7.2. Инвентаризация

В суматохе инцидента легко оставить дорогую флешку в сервере клиента.

- Ведите журнал: что взяли, что вернули.
- Маркируйте каждый инструмент (гравировка или наклейка) своим именем и телефоном.

7.3. Санитария данных

После каждого выезда все служебные флешки должны форматироваться. Данные переносятся в защищенное хранилище. Чемоданчик должен быть «стерильным» перед новым заданием.

Часть 8. Три уровня комплектации (Loadouts)

Не нужно таскать всё всегда. Модульность — ключ к успеху.

Уровень 1: EDC (Everyday Carry) — «Городской разведчик»

Вес: ~1.5 кг. В рюкзаке. Для повседневных задач, быстрых выездов и спонтанной диагностики.

- Отвертка с битами (набор Wiha в ручке).
- Патч-корд плоский (1 м).
- Консольный кабель USB-C -> RJ45 (FTDI).
- USB-хаб с Ethernet.
- Набор переходников USB.
- Power Bank 10000 mAh.
- Wi-Fi адаптер (ALFA).

- Мультишул.
- Фонарик.

Уровень 2: Аудитор — «Полевой инженер»

Вес: ~4 кг. Рюкзак + подсумок. Для запланированного пентеста или аудита на объекте.

- **Все из EDC +**
- Кабельный тестер (Wiremap).
- Набор кабелей (патч-корды, удлинители).
- Мини-роутер и свич.
- Мощный Power Bank (20000 mAh) и GaN зарядка 100W.
- Обжимка и коннекторы.
- Wi-Fi анализатор (спектр).
- Внешний SSD для бэкапов.

Уровень 3: Heavy Response — «Тяжелая артиллерия»

Вес: 6+ кг. Жесткий кейс (Pelican). Для форензики, восстановления после катастроф, работы в сложных условиях.

- **Все из Уровня 2 +**
- Write-Blocker (Tableau).
- Набор адаптеров для дисков (IDE/SATA/NVMe/ZIF).
- Запас защищенных флешек.
- Паяльник (портативный, например, TS101) и расходники.
- Пакеты Фарадея и пломбы.
- Запасные батарейки.
- Документы, бланки Chain of Custody.

Реальные кейсы: Цена ошибки

Кейс №1: «Драма с Type-C»

Аудитор приехал в дата-центр. Ему нужно подключиться к управлению стоечным сервером через локальный порт. У него MacBook Pro только с портами Thunderbolt (USB-C). У него есть Ethernet-кабель, но нет USB-C Ethernet адаптера. Wi-Fi в экранированной серверной не ловит.

Итог: 2 часа ожидания, пока местный админ найдет переходник. Потеря авторитета.

Кейс №2: «Сгоревший порт»

Пентестер подключил свой ноутбук к неизвестному устройству в стене (Ethernet розетка), чтобы просканировать сеть. Оказалось, что это был проприетарный порт цифровой телефонии с PoE (Power over Ethernet) нестандартного вольтажа.

Итог: Сгоревшая сетевая карта материнской платы ноутбука за \$2000.

Решение: Использовать дешевый USB-Ethernet адаптер как «предохранитель» или проверять линию мультиметром.

Кейс №3: «Иллюзия тишины»

Офис жаловался на плохой Wi-Fi. Штатный админ смотрел приложением на телефоне и видел отличный уровень сигнала. Аудитор привез спектроанализатор.

Итог: Выяснилось, что за стеной работает неисправная промышленная установка, которая «шумит» на частоте 2.4 ГГц, убивая соотношение сигнал/шум, но не видимая обычными Wi-Fi сканерами.

Чемоданчик ИБ-специалиста — это инвестиция в ваше спокойствие и профессионализм. Пентест начинается не с запуска Metasploit, а с возможности физически подключиться к целевой системе. Форензика начинается не с анализа реестра, а с побитовой копии диска, сделанной без искажения данных.

Не экономьте на кабелях и инструментах. В критический момент, когда сервер лежит, директор кричит, а счетчик убытков крутится, именно надежная отвертка и правильный консольный кабель станут вашими лучшими союзниками. Соберите свой комплект, держите его в порядке, и будьте готовы к любым сюрпризам физического мира.